

Olinda live website security check

Date: 02 October 2026, 08:49:01 to 02 October 2026, 08:51:13, Australia/Hobart.

Primary page: https://portal-olinda.rafiSTACKS.dev/test_website.html

Assessment: Limited, unauthenticated, non-invasive HTTP/TLS baseline. Not a penetration test or compliance certification.

Result

The tested HTTPS endpoints negotiated TLS 1.3 with certificate verification. Selected protected dashboard endpoints rejected unauthenticated requests. Expected origins passed CORS preflight and an unapproved origin was rejected. No configured secret-pattern matches appeared in the selected public assets.

The deployed frontend is missing security headers. Three dashboard requests initially timed out and passed on retry. These checks do not establish that the chatbot cannot be exploited or that college infrastructure is isolated.

Scope and method

- Portal homepage and test page, selected widget JavaScript/CSS and portal boot script.
- Chat backend: health, disabled documentation endpoints, HTTP-to-HTTPS behavior and chat preflight.
- Dashboard backend: health, disabled documentation endpoints, five protected read endpoints, HTTP-to-HTTPS behavior and login preflight.
- 34 HTTP requests, including retries and policy confirmation, and 4 verified TLS handshakes. Concurrency capped at three; request timeout 25 seconds. This was a small availability/security check, not a load test.
- Only GET and OPTIONS requests; no credentials, chat prompts, paid AI calls, login attempts, uploads, mutations, fuzzing or attack payloads. No inspection of private records.
- The college website, Supabase endpoint and LLM providers were not directly tested. CORS preflight used the college origin string; this did not contact the college website.
- Inspected public response bodies were capped at 1 MiB per response. Evidence retains selected headers, statuses and match counts, not response bodies or matching secret values.

Findings and actions

F-01: Frontend content/frame protection missing - Medium hardening priority

Both the portal homepage and test page returned HTTP 200 without a Content-Security-Policy header or detected CSP meta tag. Neither supplied X-Frame-Options. An injected-script or clickjacking exploit was not demonstrated; this is an observed protection gap.

Action: Apply the intended CSP to the deployed portal, including an appropriate frame-ancestors restriction. Confirm the actual Vercel project's configuration location: locally prepared root headers are not visible in the current responses. Allow the hosted widget scripts/styles/images and backend connections so the policy does not break the widget.

F-02: Other frontend response headers missing - Low hardening priority

The checked frontend pages did not return X-Content-Type-Options, Referrer-Policy or Permissions-Policy. HSTS was present. The backend responses did return nosniff, no-referrer, no-store and frame-denial headers.

Action: Apply and verify frontend nosniff and an appropriate referrer policy. Permissions-Policy can explicitly disable unused browser capabilities. This finding is not evidence of an exploit.

F-03: Transient dashboard timeouts - Availability observation

Initial requests to dashboard /health, /docs and /redoc timed out at approximately 25 seconds. Follow-up checks returned /health 200 and /docs and /redoc 404. A Render cold start is a possible explanation, but the cause was not established.

Action: Compare the timestamps with Render logs and measure cold/warm response times. Do not promise a latency SLA from this sample. No plan upgrade has been made.

O-01: Wildcard CORS on public frontend HTML/assets - Informational

Selected public frontend responses supplied Access-Control-Allow-Origin: *. Public widget assets need cross-origin loading and contain no intended credentials. This does not mean the backend API accepts every browser origin; its tested preflight remained restricted. Wildcard headers on HTML pages are unnecessary for this integration.

Action: Optionally scope wildcard CORS to public widget assets. Do not replace the backend origin allowlist with *.

Positive observations

Check	Observed result	Limit
TLS certificates/protocol	All four tested hosts negotiated TLSv1.3 with verified certificates.	Client-to-public-endpoint only; backend/provider/database/internal hops were not measured.
Transport enforcement	HTTP health requests reached HTTPS endpoints; HSTS observed on selected frontend and backend responses.	Full redirect chains/minimum accepted TLS versions were not audited.
Staff endpoint protection	/api/me, /api/staff, /api/analytics, /api/unanswered and /api/chunks returned 401 without credentials.	No authenticated role, stolen-token or object-authorization testing performed.
Chat CORS	College, widget-demo and portal origins returned 200 preflight with the matching allowed origin. Unapproved origin returned 400 without ACAO.	CORS is a browser control; direct scripts can still call anonymous chat within controls.
Dashboard CORS	Portal origin allowed; unapproved origin rejected with 400 and no ACAO.	No write request or login attempted.
API documentation	/docs, /redoc and /openapi.json returned 404 on both APIs after dashboard retries.	Does not conceal or secure the underlying endpoints by itself.
Selected public asset key patterns	Zero matches for configured Google, Groq, Supabase-secret and private-key-block patterns.	Limited files/patterns only; not a Git-history, JWT/service-role-key or complete secret audit.
Widget assets	Checked entry/module/network/session/CSS files returned 200.	No browser rendering, chat conversation or plugin execution test performed.

Not tested / evidence still required

Area	Next test/evidence
Minute/day limits	Controlled staging tests, concurrent instances, rollover, storage failure and spoofed forwarding headers. No limit exhaustion performed here.
SQL injection, XSS, CSRF, uploads	Authorized API-aware active/manual tests, including authenticated staff flows. No scanner attack payloads sent.
LLM prompt security	Real-model jailbreak, prompt leakage, malicious-document and synthetic PII tests with an approved AI budget.
Dependencies and historical secrets	Installed dependency audit plus repository/history secret scan.
Database RLS	Post-fix advisor results and public-role denial/backend-access tests. The user supplied earlier warnings; this scan did not verify their resolution.
Privacy/encryption	Data inventory, provider settings, retention and hosting storage/backup encryption evidence. Application chat encryption is deliberately disabled.
DDoS and college isolation	Hosting controls, network architecture and credential-permission evidence. No DDoS or college-network test.
Performance	Approved load/stress tests and warm/cold latency distribution. Current chat is non-streaming; no TTFT metric measured.
Password policy	The local environment-staff minimum-length check remains temporarily disabled at the user's request. Actual production password strength was not tested. Restore the policy before client security sign-off.
Independent penetration test	A scoped, authorized manual assessment and remediation/retest report.

Recommended order

1. Deploy/verify frontend headers and retest these findings.
2. Verify public database denial and backend access after the approved SQL fix.
3. Restore the intended staff password policy and perform a dependency/history-secret audit.
4. Approve staging scope, budget and test accounts, then run API, prompt, rate-limit and load tests.
5. Obtain independent penetration testing if required by the client.

Evidence and references

This run used a custom Python HTTP/TLS checker, not OWASP ZAP or Burp Suite. Previous local regression results are separate evidence and were not rerun by this live assessment. The source report and auxiliary scan files were removed at the owner's request after this PDF was created.

Guidance: [OWASP Web Security Testing Guide](#), [OWASP HTTP header guidance](#), [ZAP passive baseline description](#).

No code/configuration was deployed, no database data was intentionally changed, and no paid AI request was made. Protected API GETs can increment normal application traffic counters; this report does not imply zero operational requests. No report was published publicly.